# Monthly Intelligence Dispatch

March 2021

**The Group-IB Monthly Threat Intelligence Dispatch (Group-IB MTID)** is a monthly newsletter by Group-IB, an international company that specializes in preventing cyberattacks and developing information security products. The dispatch aims to provide information about the latest cyberthreats, criminal groups' attacks, data leaks, and malware. The document contains news about arrests, legal action against hacking groups, short-term forecasts, and recommendations to help take timely measures to reduce security risks and ensure protection against cyberthreats. Group-IB MTID is intended for internal use only and its distribution is not permitted.

# Key findings

- Group-IB released a new solid research «Ransomware Uncovered 2020/2021» that covers one of the most relevant cyberthreats during the COVID-19 pandemic.
- SITA (multinational information technology company providing IT and telecommunication services to the air transport industry) falls victim to cyberattack.
- Proofpoint researchers attributed several campaigns against Tibetan organizations all over the world to a Chinese APT actor TA413.
- Qualys, a cybersecurity company confirmed being impacted by the recent cyberattack involving outdated Accellion FTA (File Transfer Application).
- French cybersecurity company StormShield, a major provider to the French government revealed that it had suffered a security breach.
- Researchers detected a new version of Ryuk ransomware updated with worm-like capabilities that allow the malware to propagate itself – machine to machine – within the infected network.
- Microsoft experts disclosed information about three malware families (GoldMax, Sibot and GoldFinder), behind the attacks against SolarWinds.
- Chinese state hackers target Linux systems with new sophisticated backdoor.
- Catalan police arrested four people suspected to be members of a criminal group behind FluBot Android malware that infected at least 60,000 devices.

Group-IB released a new solid research “Ransomware Uncovered 2020/2021” that covers one of the most relevant cyberthreats during the COVID-19 pandemic. According to the research the number of ransomware attacks increased by 150% over the course of the year. Average downtime of the compromised company is 18 days, while the ransom demands almost doubled up to $170,000. Researchers found out that Maze, DoppelPaymer, and RagnarLocker were the greediest groups, with their ransom demands averaging between $1 million and $2 million. Large corporate networks are at risk - targeted ransomware attacks (The Big Game Hunting) paralyzed the work of such giants as Garmin, Canon, Campari, Capcom and Foxconn in 2020. Business downtime from one attack, averaged 18 days. Most of the attacks analyzed by Group-IB occurred in North America and Europe, where the majority of the Fortune 500 companies are located, as well as in Latin America and the Asia-Pacific region. The first attacks were registered in Russia. According to the forecast of the experts, ransomware attacks are likely to target Russian business and then enter CIS. Russian-speaking hacker group OldGremlin defied the unspoken rule about hacking on home soil. Group-IB released its first report about the gang in September 2020. Since spring 2020, OldGremlin has conducted at least 9 campaigns and attacked exclusively Russian businesses: banks, industrial enterprises, medical organizations and software developers. In August 2020 OldGremlin attacked a major company with a network of regional subsidiaries and demanded a ransom of $50,000 for decrypting the data.

| | |
|---|---|
| **TA413** | **Proofpoint** experts discovered a malware campaign related to Chinese APT actor TA413. The hackers targeted Tibetan organizations all over the world using malicious browser extensions for Firefox, which stole Gmail and Firefox data and then delivered malware to the infected systems. The cybercriminals distributed phishing emails that lured the victims into installing fake Flash updates necessary to open the content of the page. The malicious browser extension appears to be based on a legitimate Gmail notifier extension (restartless), which gave the hackers full access to the victims' email. |
| **StormShield** | French cybersecurity company StormShield, a major provider to the French government revealed that it had suffered a security breach. An unidentified hacker stole customers' personal and technical data after gaining access to the corporate portal. Stormshield also discovered that some of the source code for the Stormshield Network Security (SNS) firewall used in French government networks was also stolen. Investigation backed up by the French National Agency for Security of Information Systems (ANSSI) is in progress. The ANSSI experts are now assessing the possible impact of the hacking on government systems. |
| **SITA** | SITA (multinational information technology company providing IT and telecommunication services to the air transport industry) officially confirmed falling victim to a cyberattack. The data security incident involved leaks of data stored on SITA Passenger Service System (SITA PSS), which operates passenger processing systems for airlines. |

| | |
|---|---|
| **SolarWinds** | Microsoft experts disclosed information about three malware families (GoldMax, Sibot and GoldFinder), behind the attacks against **SolarWinds**. According to the researchers, threat actors used this malware during the second phase of software developer compromise. Recent investigations have identified these three pieces of malware being used in late-stage activity by NOBELIUM. Written in Go, GoldMax acts as C&C backdoor that allowed the threat actors to obfuscate their activity and avoid being detected. The malware is equipped with a decoy network traffic generation feature that allows it to surround its malicious network traffic with seemingly benign traffic. Implemented in VBScript, Sibot was designed to achieve persistence on the infected system to execute extra payloads. GoldFinder also helped the cybercriminals to identify HTTP proxy servers and other redirectors. |
| **RedXOR** | According to **Intezer**, Chinese state hackers target Linux systems with new sophisticated backdoor named RedXOR. The malware was named RedXOR for its network data encoding scheme based on XOR. Investigation revealed that the samples of the malware were compiled with a legacy GCC compiler, which hints that RedXOR is used to target legacy Linux systems. The new malware can collect system data (MAC address, username, kernel and distribution version), interact with files, execute commands with system privileges, shell commands and even update remotely. |

**Perl.com**

Unidentified attackers hijacked perl.com domain and installed malware that redirects users to an IP address tied to malware campaigns. The rightful owner of the perl.com domain is The Perl Foundation, a non-profit organization that seeks to develop Perl and Raku programming languages. Perl.com was created in 1994, since then the web resource is considered the official platform of Perl language. Due to the recent cyber attack, users were encouraged to avoid visiting this site for now. After the attackers gained control of the domain, the site began to render a blank page, whose HTML contained Godaddy scripts. Moreover, shortly after the hack, perl.com the domain was put up for sale for $190,000 on afternic.com. The Google Cloud IP address that Perl.com is now hosted at, namely 35.186.238[.]101, is known to have been used for malware distribution in the past, including the Locky ransomware campaign.

**Qualys**

Qualys, a cybersecurity company confirmed being impacted by the recent cyberattack involving outdated Accellion FTA (File Transfer Application). The Clop ransomware gang published screenshots of files allegedly stolen from Qualys. The leaked data includes purchase orders, invoices, tax documents, and scan reports. According to Bleeping Computer, The Accellion FTA device was located at fts-na.qualys.com. The device has since been decommissioned with Shodan showing it was last active on February 18th, 2021. The cybercriminals, however, successfully compromised the company.

## Ursnif

Ursnif banking trojan continues to be one of the most dangerous threats for organizations around the world. This time it targeted at least 100 banks and stole more than 1700 sets of credentials. The trojan is usually spread via phishing emails written in different languages. Ursnif is installed on the victim's device only after downloading the backdoor, that allows the attackers to bypass common security mechanisms and gain a high level of access to the system, network or programs. Ursnif is a so-called "fileless malware", that is, it leaves almost no traces in the system. Since the trojan is installed after the backdoor and requires information received via the C&C server to activate it, Ursnif can remain unnoticed for hours until it eventually starts malicious activity. Besides stealing banking data, the trojan can gain access to some of the victim's emails, browsers, and cryptocurrency wallets.

An unidentified cybercriminal on a popular hacker forum is selling databases that allegedly contain user credentials stolen from three Android VPN services: SuperVPN, GeckoVPN and ChatVPN. The hacker offers credentials of more than 21 million users. It is quite an interesting leak considering that SuperVPN has 100+ million downloads on the Play store, while GeckoVPN has 1,000,000 installs and ChatVPN boasts 50,000+ installs. The cybercriminal is selling email addresses and randomly generated strings used as passwords for an undisclosed sum. It appears that the archives with stolen data contain device serial numbers, phone types and manufacturers, device IDs, and device IMSI numbers. The hacker claims that the data has been exfiltrated from publicly available databases.

| | |
|---|---|
| VPN | An unidentified cybercriminal on a popular hacker forum is selling databases that allegedly contain user credentials stolen from three Android VPN services: **SuperVPN, GeckoVPN and ChatVPN**. The hacker offers credentials of more than 21 million users. It is quite an interesting leak considering that SuperVPN has 100,000,000+ downloads on the Play store, while GeckoVPN has 1,000,000 installs and ChatVPN boasts 50,000+ installs. The cybercriminal is selling email addresses and randomly generated strings used as passwords for an undisclosed sum. It appears that the archives with stolen data contain device serial numbers, phone types and manufacturers, device IDs, and device IMSI numbers. The hacker claims that the data has been exfiltrated from publicly available databases. |

## Ryuk

Researchers detected a new version of Ryuk ransomware updated with worm-like capabilities that allow the malware to propagate itself – machine to machine – within the infected network. The propagation is achieved by creating a scheduled task on a remote machine. French National Agency for the Security of Information Systems (ANSSI) found the sample with new capabilities earlier this year. The analysis of the sample showed that the malware is based on a randomly-chosen open-source software which is then recompiled and backdoored. Once launched, Ryuk ransomware tries to spread itself on every reachable machine on which Windows RPC accesses are possible. In order to find these machines, it generates every possible IP address on local networks and sends an ICMP ping to each of them. Moreover, it also tries to reach devices in standby mode by listing IP addresses uploaded into the ARP cache from the subnet routers. After scanning through the victims ARP tables, the ransomware sends a Wake-On-LAN packet to each host. Ryuk mastered this technique a year ago. The malware then lists all the sharing resources opened on the found IPs, mounts each of them and tries to encrypt their content. Ryuk copies itself with a rep.exe or lan.exe suffix by creating scheduled tasks using schtasks.exe Windows system tool. No mechanism for blocking the execution of the ransomware has been identified.

.

# Arrests and sentences

**FluBot**

Catalan police arrested four people suspected to be members of a criminal group behind FluBot Android malware that infected at least 60,000 devices. The malware was first detected by ThreatFabric in the beginning of the year. Recently, analysts from the Swiss cybersecurity company PRODAFT prepared a detailed report about this malware. Apparently, it was the data collected by the experts that led to the arrest of the malware operators. FluBot is a banking Trojan capable of displaying fake login screens on top of other apps. This way, the malware steals e-banking credentials and card details of the victims.

The explosion in the number of infected devices probably occurred because the Flubot has a worm-like capability that allows the malware operator to gain access to the victim's entire contact list, deliver it to the C&C server and then use it to send out malicious SMS spam. According to PRODAFT, FluBot operators had collected more than 11 million phone numbers (about 25% of Spain's population), while Catalan officials said they tracked at least 71,000 spam SMS messages sent by the malware gang.

Spanish authorities report having arrested 4 suspects aged between 19 and 27. The names of alleged malware operators were not disclosed, two members, deemed the leaders of the gang, were detained, while the other two were set free but required to appear in court every 15 days. It appears that one of the two gang leaders was responsible for the technical side like writing the malware code and creating fake bank login pages. Catalan investigators raided the apartments of the suspects and seized cash, laptops, documents, and mobile devices, some of which were allegedly bought with the victims' money.

# Forecasts and warnings

- Ransomware is considered the most serious cyber threat in 2020-2021. There are two main reasons for this. First, the results of ransomware attacks are visible to everyone, and second, this area of malicious activity brings cybercriminals significant earnings. In 2021, the number of ransomware attacks will only grow, and the tactics used by cybercriminals will become more sophisticated. At the same time, the damage done by ransomware attacks even exceeds the negative impact caused by the actions of APT actors. Indeed, in both cases, cybercriminals gain access to the organization's resources with administrator rights, use mechanisms to hide their activity, and often steal valuable information. Ransomware attack, however, paralyzes the entire infrastructure, disrupting or even halting business operation.
- The number of cyberattacks is growing, their complexity is increasing, and it is becoming more difficult to ensure protection against them. The income of APT groups that target financial institutions decreased as droppers involved in withdrawing funds could not fully carry out their activities due to the pandemic. Therefore, hacker groups began to team up with the owners of the ransomware and sell them the access to the networks of compromised companies.
- To avoid falling victim to malware attacks, keep your system updated, use strong unique passwords at least 8 characters long, avoid dictionary words, phrases, and patterns that are easy to guess.

If you wish to receive more detailed information about a specific incident, threat, or criminal group:

Please contact us.

We can conduct investigations to give you the maximum intelligence on the threats targeting your organization.

+1 917 809 47 41
+7 495 984 33 64
intelligence@group-ib.com